

Fundamental Rights Impact Assessment

Regulation: EU 2024/1689 Art. 27 **Generated:** 2026-04-22T12:27:52.933771+00:00 **Status:** draft

Deployer

- **Organisation:** Example Engineering GmbH
- **Contact:** [DEPLOYER: accountable contact person and role]
- **Role:** deployer

Trigger

- **Category:** other_high_risk
- **Reference:** Other Annex III high-risk deployment with deployer obligations

1. Process description (Art. 27(1)(a))

- **Agent:** Codebase Security Audit (external/codebase-security-audit v2, security)
- **Agent description:** Runs automated SAST, dependency, and secret-leak scans on a codebase and summarises findings in a structured report.
- **Deployer process summary:** Weekly scheduled scan of all active repositories; findings are routed to the owning team via Slack.

2. Duration and frequency (Art. 27(1)(b))

- **Intended duration:** [DEPLOYER: calendar duration or 'ongoing']
- **Frequency:** Weekly per repository
- **Estimated volume per month:** [DEPLOYER: approximate number of affected persons per month]

3. Affected persons (Art. 27(1)(c))

Primary categories:

- No direct personal-data processing; engineering data only

Vulnerable groups considered:

- [DEPLOYER: minors, elderly, persons with disabilities, linguistic minorities, etc.]

Special categories of data (GDPR Art. 9): [DEPLOYER: GDPR Art. 9 data processed, if any]

4. Specific risks of harm (Art. 27(1)(d))

- **Platform risk class:** limited

Identified potential harms:

- Missed vulnerability (false negative)
- Exposure of sensitive scan content if report is mis-routed
- **Severity assessment:** [DEPLOYER: qualitative severity scoring per identified harm]
- **Likelihood assessment:** [DEPLOYER: qualitative likelihood scoring per identified harm]

5. Human oversight (Art. 27(1)(e))

Platform-provided measures:

- Immutable event log per execution (Art. 12)
- Ephemeral compute: fresh VM per task, destroyed on completion (Art. 15)
- Signed capability card identifying model, data access, and side effects (Art. 13)
- Machine-readable Art. 50 provenance headers on every output

Deployer-provided measures:

- Security lead reviews critical findings before dissemination
- Scan reports never leave internal infrastructure
- **Instructions for Use (IFU) version:** `capability-card@v2`

6. Governance and mitigation (Art. 27(1)(f))

Internal governance:

- [DEPLOYER: escalation path when oversight detects an issue]
- [DEPLOYER: cadence of post-deployment review]
- [DEPLOYER: named role responsible for stopping deployment]
- **Complaint mechanism:** [DEPLOYER: how affected persons contest an outcome; response SLA]
- **Authority reporting (Art. 73):** [DEPLOYER: process for reporting serious incidents to the national MSA (Art. 73)]
- **DPIA reference (Art. 27(4)):** [DEPLOYER: reference to the GDPR DPIA; Art. 27(4) allows DPIA content to cover parts of this FRIA]

Generated by the agents.renemurrell.de FRIA scaffolding engine. Sections marked [DEPLOYER: ...] require completion by the deploying organisation. This document does not replace legal counsel.